

Third-Party Risk Management

Strength in Strategy, Power in Protection



Meet The Team



Jeremy Anthony
Technical Consultant



Theo Rhynie
Strategy Consultant



Latoyah George
Associate Consultant



James Caruso
Technical Consultant



Popy Halder
Technical Consultant



Kristoffer Debrosse
Associate Consultant

Agenda

- **Overview of TPRM**
- **Impact of TPRM**
- **Frameworks**
- **Risk Analysis**
- **Areas of improvement**
- **Key Takeaways**

Why Are We Here?



- Secure Ernst Bank's operations by managing 1,500+ third-party vendors.
- Mitigate risks tied to third-party relationships.
- Implement robust risk management frameworks (NIST, NIST 800-53) to protect operations, reputation, and client trust.

What is Third-Party Risk Management?

- **Third-Party Risk Management (TPRM)** is the process of identifying, assessing, mitigating, and monitoring risks associated with external vendors, suppliers, and service providers that an organization relies on.



Why Should Ernst Bank want a TRPM?

■ BEFORE TPRM

- **Regulatory & Compliance Issues**
- **Operational Disruptions**
- **Financial & Reputational Risks**
- **Capital One (2019) Data Breach**

■ AFTER TPRM

- **Enhanced Data Security & Cyber Resilience**
- **Stronger Compliance & Legal Protection**
- **Improved Business Continuity**



Capital One (2019 Data Breach)

- **Third-Party Vendor Breach:** In 2019, Capital One's breach stemmed from a misconfigured firewall in a third-party cloud service.
- **Financial Consequences:** \$190 million settlement.
- **Reputational Damage:** Loss of customer trust and tighter cloud security oversight.

FFIEC Regulatory

- Regular Risk Assessments
- Due Diligence/Service Provider Selection
- Contract Review
- Ongoing Monitoring
- Termination & Transition



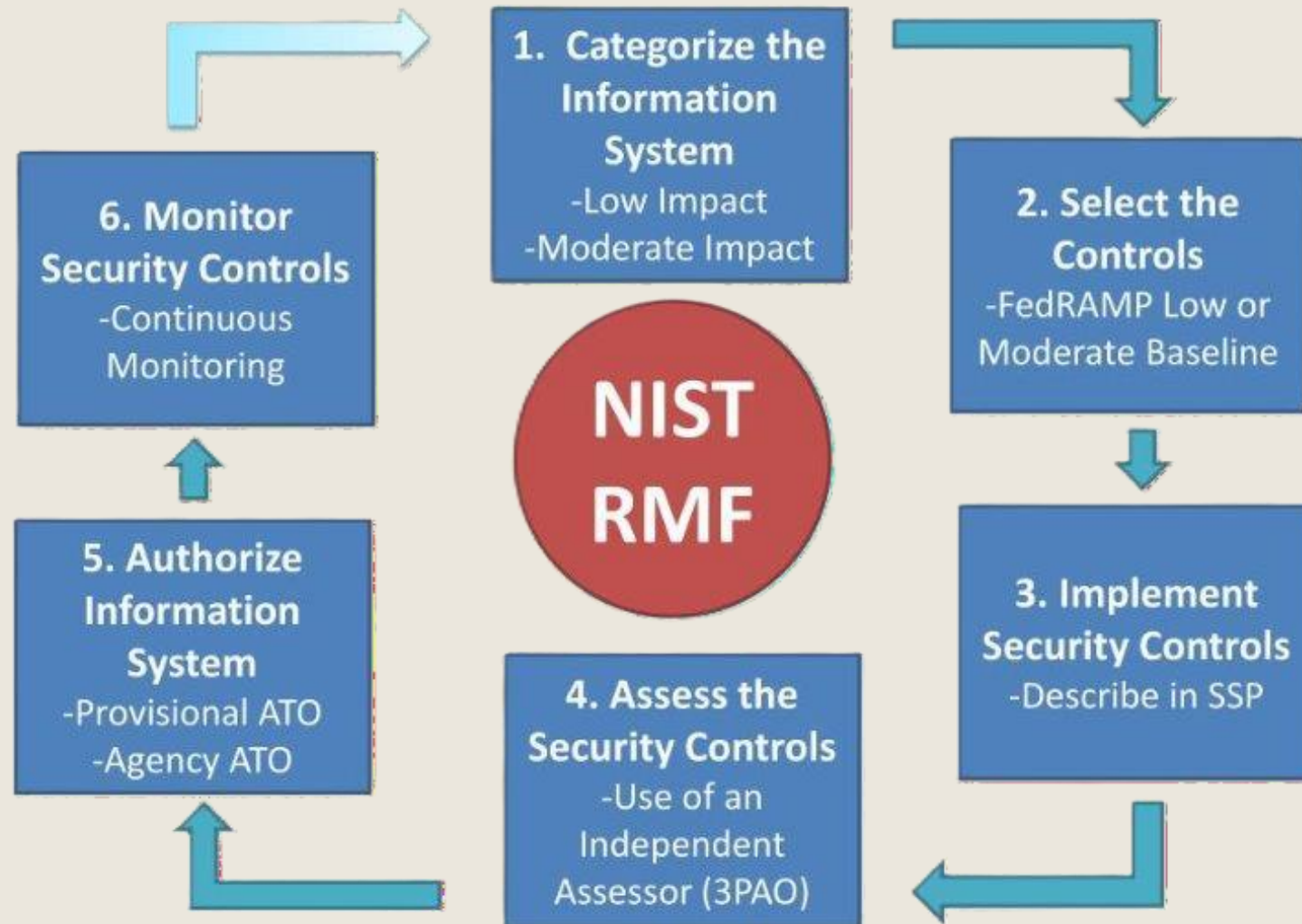
NIST Frameworks

NIST SP 800-53

- A catalog within a security standard containing controls to be implemented
- Reduce impact on risks involved with Third Party
- These controls include:
 - Security Audits
 - Access Controls
 - On-going monitoring
 - Physical Controls



NIST Risk Assessment Framework



Risk Analysis Scale

Likelihood	Severity			
	4	8	12	16
	3	6	9	12
	2	4	6	8
	1	2	3	4

Very High	12-16	Critical Risk that should be taken care of immediately.
High	8-11	High impact based on severity and likelihood of risk
Medium	4-7	Moderate impact based on severity and likelihood of risk
Low	1-3	Little to no impact based on severity and likelihood of risk

Inherent Risk Questionnaire

Let's Assess Your Current Risk!!



Inherent Risk Questions	Answers
What data breaches has Ernst Bank experienced in the past three years?	Moderate security incidents, limited impact
How extensive are the contracts put in place with third party partnerships?	Basic - Covers fundamentals lacks details
What proportion of security incidents are discovered by external parties rather than internal systems?	75%
How quickly can Ernst launch a contingency plan to restore operations after disruption?	Moderate - Plans exist but lack speed and efficiency.
How often does the organization monitor the use of data by third-party vendors to prevent unauthorized access?	Occasionally - Periodic reviews, but not consistent.
What is the criteria for selecting third-party vendors who will handle sensitive data?	Minimal - Few security checks
How does Ernst bank ensure their thrd party vendors are complying to regulatory bodies ?	Only when issues arise
How often does Ernst Bank review their third party agreements?	Annually
How often does Enst Bank communicate with third-party vendors?	Occasionally - Scheduled check ins
How often does Ernst Bank train their employees on cyber threats?	Every 6 Months

Control Questionnaire

Control Risks Questions	Answers
How prepared is the third party to handle cybersecurity incidents?	Written plan but not regularly tested
What type of network security measures does the third party have?	No formal incident response plan
What security measures does the third party implement for cloud-based services?	Basic plan with key gaps
How does the third party ensure adherence to contractual obligations?	Written plan but not regularly tested
How does the third party train employees on data security?	Fully documented and tested response plan
How often does the third party update its security policies?	Security training is only given to new hires
What fraud detection measures does the third party implement?	Only when something goes wrong or the law requires it
How does Ernst Bank determine the level of access a third party vendor has to information?	Rule-based fraud detection
How often does the third party conduct internal security audits?	Access is based on what the vendor requests
How does the third party stay updated on new regulatory standards?	No formal security audit process
How does the third party manage access to Ernst Bank's sensitive data?	Bi-annual legal and regulatory reviews
What happens if the third party faces financial difficulties ?	Password-based authentication only
	Only reviewed if problems are reported

Inherent Risk Assessment

Questions	Risk Category	Response Options	Severity	Likelihood	Risk Score	Risk Level
1	Data Breach Risk	Moderate security incidents, limited impact	3	3	9	High
2	Contractual Compliance Risk	Basic - Covers fundamentals lacks details	3	3	9	High
4	Operational Risk	Moderate - Plans exist but lack speed and efficiency	3	3	9	High
5	Third- Party Monitoring Risk	Occasionally - Periodic reviews, but not consistent	3	3	9	High
6	Vendor Security Risk	Minimal - Few security checks	4	4	16	Very High
7	Regulatory Compliance Risk	Only when issues arise	3	3	9	High
8	Third-Party Agreement Risk	Annually	4	4	16	Very High
9	Weak Vendor Oversight	Occasionally - Scheduled check ins	3	3	9	High
10	Insider threat	Every 6 Months	4	4	16	Very High

Average Inherent Risk: **11.8**

Very High	12-16	Critical Risk that should be taken care of immediately.
High	8-11	High impact based on severity and likelihood of risk
Medium	4-7	Moderate impact based on severity and likelihood of risk
Low	1-3	Little to no impact based on severity and likelihood of risk

Residual Risk Assessment

Threat/Controls	Inherent Risk	Residual Risk
Data Breach Risk	9	6.99
Contractual Compliance Risk	9	5.81
Undetected Risk Exposure	16	13.14
Operational Risk	9	5.37
Third- Party Monitoring Risk	9	5.55
Vendor Security Risk	16	7.57
Regulatory Compliance Risk	9	5.32
Third-Party Agreement Risk	16	12.6
Weak Vendor Oversight	9	6.71
Insider threat	16	12.26

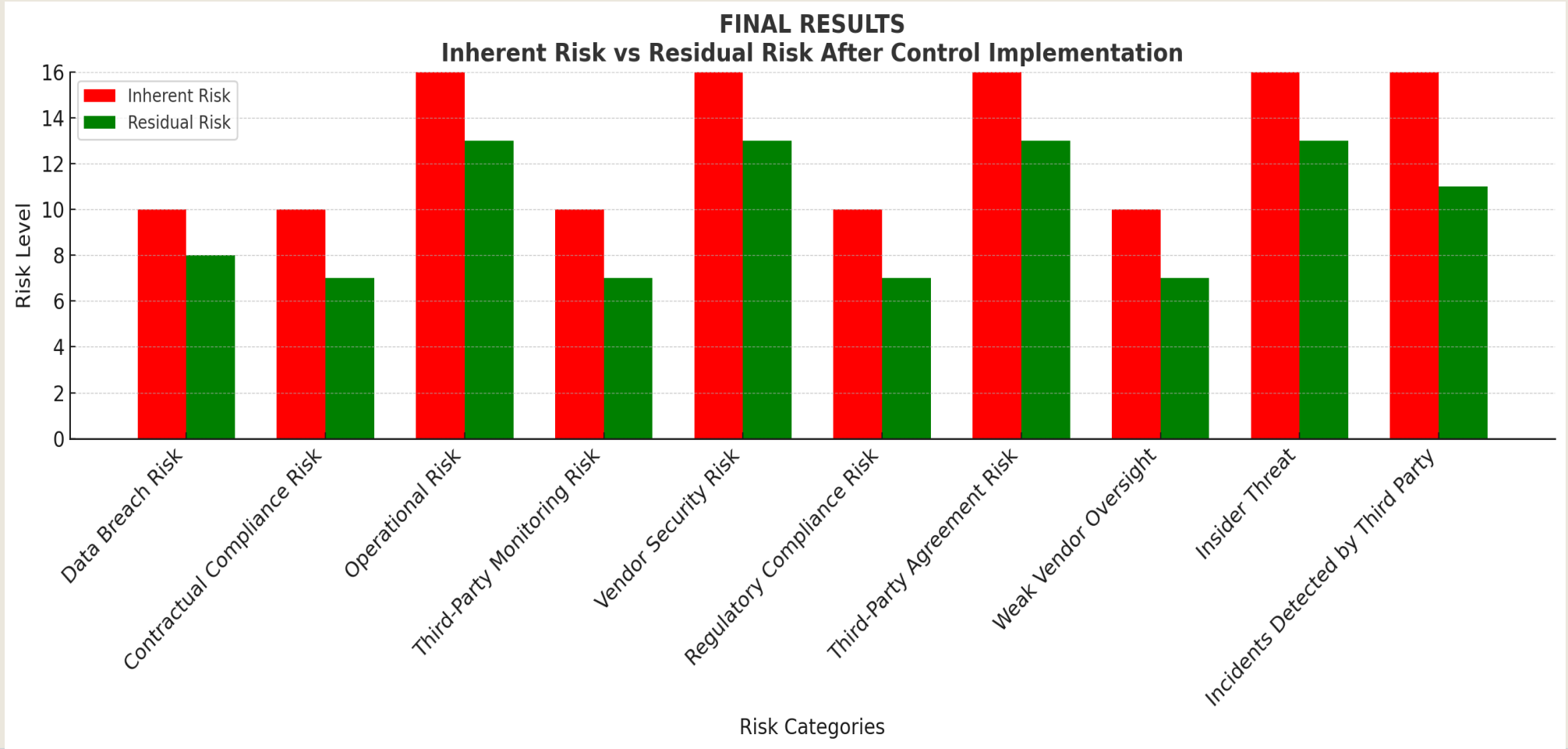
TOTAL INHERENT RISK VS. TOTAL RESIDUAL RISK

118

VS.

81.32

Most Effective Risk Controls



On Average, 5 out of 7 controls reduce risk by **15%**



Vendor Security Risk alone dropped by **45%** with Ernst Bank's controls in place

Opportunities For Improvement



Insider Threat only reduced 23%



Third-Party Agreement Risk only reduced 22%



Both risks can lead to legal penalties, reputation damage, and operational disruption

Data Monitoring Tool

Estimated Costs (Annual):

- Tool License: \$30,000 - \$150,000
- Setup & Integration (One-Time): \$10,000 - \$50,000
- Trainings & Support: \$15,000 - \$40,000
- Operational Staff: \$20,000 - \$60,000
- **Total Year 1 Cost: \$75,000 - \$300,000**

Estimated Benefits:

- Avoided Insider Incidents: \$250,000 - \$1M+ per incident
- Avoided Fines (Compliance): \$100,000 - \$500,000+
- Efficiency Gains: \$20,000 - \$100,000 annually
- **Total Benefit: \$370,000 - \$1.6M+**



CYBERARK[®]
The Identity Security Company[™]

- Acts as a control for the Insider Threat Risk
- Meets FFIEC, GDPR, PCI-DSS, and SOX regulations.
- Supports AI and machine learning security initiatives.

SLA Monitoring Tool

Estimated Costs (Annual):

- **Tool License:** \$5,000 – \$50,000
- **Setup & Integration (One-Time):** \$2,000 – \$10,000
- **Training & Support:** \$3,000 – \$10,000
- **Operational Staff:** Often minimal (automated alerts)
- **Total Year 1 Cost:** \$10,000 – \$70,000

Estimated Benefits:

- **Avoided SLA Breaches/Fines:** \$60,000 – \$300,000+ annually (depending on contracts)
- **Improved Vendor Performance:** Reduces downtime, improves service quality
- **Efficiency Gains:** Saves manual tracking time, estimated at \$20,000 – \$50,000 annually
- **Total Benefit:** \$80,000 – \$350,000+



- **Real-time SLA monitoring**
- **Automated alerts for SLA breaches**
- **Improved vendor accountability**
- **Scalable and flexible**
- **Meets GDPR and regulations**

****Ensures SLA compliance and vendor performance reducing operational risks.**

Timeline for Implementation

Phase 1: Planning & Assessment

- Set scope and objectives across key business units
- Identify critical assets, and high-risk areas
- Perform gap analysis and readiness assessment
- Align with compliance standards(GDPR, PCI-DSS, and SOX)

(Month 1-2)

Phase 2: Pilot Implementation

- Deploy Insider Threat controls in selected high-risk areas
- Test SLA alert automation and real-time monitoring
- Capture baseline metrics for accountability tracking

(Month 3-6)

Phase 3: Full-Scale Rollout

- Expand deployment to all privileged accounts across
- Enable policy enforcement and user behavior analytics
- Train users, IT admins, and compliance teams

(Month 6-G)

Phase 4: Continuous Monitoring

- Monitor and fine tune policies based on AI insights
- Review SLA breaches and audits quarterly
- Use performance data to boost IT efficiency and ROI

Ongoing

Total Risk Reduction

Threats	Inherent Risk	Residual Risk Before Recommendation	Residual Risk After Recommendation
Data Breach Risk	9	6.99	4.58
Contractual Compliance Risk	9	5.81	3.81
Operational Risk	9	5.37	3.52
Third- Party Monitoring Risk	9	5.55	3.64
Vendor Security Risk	16	7.57	4.96
Regulatory Compliance Risk	9	5.32	3.49
Third-Party Agreement Risk	16	12.6	8.27
Weak Vendor Oversight	9	6.71	1.69
Insider Threat	16	12.26	5.36

Key Takeaways

**Ernst Bank
Third Party
Vulnerabilities**

**Risk
Methodology
Tool**

**Total Risk
Reduction**

**Cost Benefit
Analysis**

Timeline

THANK YOU

QUESTIONS?